



**Country Signer Certificate Authority
Kingdom of Belgium
Certificate Policy**

PrimeKey Solutions AB,

Table of Contents

1	Introduction.....	7
1.1	Overview	7
1.1.1	Certificate Policy	7
1.1.2	CP vs CPS	7
1.1.3	Relationship with other PKI systems.....	7
1.1.4	Scope.....	8
1.2	Document Name and Identification	8
1.3	PKI Participants.....	8
1.1.5	Certification Authority	8
1.1.6	Registration Authority (RA)	8
1.1.7	Subscribers	9
1.1.8	Relying Parties.....	9
1.4	Obligations	9
1.1.9	CA Obligations	9
1.1.10	RA obligations	9
1.1.11	Subscriber obligations:.....	9
1.1.12	Relying party obligations:.....	10
1.1.13	Repository obligations.....	10
1.1.14	Kinds of Certificates issued.....	10
1.5	Certificate Usage.....	10
1.1.15	Acceptable uses.....	10
1.1.16	Prohibited uses	10
1.6	Policy Administration	10
1.7	Contact Information	10
2	Publication and repository responsibilities.....	11
2.1	Repositories	11
2.1.1	Repository Obligations.....	11
2.2	Publication of Certification Information.....	11
2.2.1	Publication of Certificates and Certificate Status	11
2.2.2	Publication of CA Information.....	11
2.3	Time and Frequency of publication	11
2.4	Access Control on Repositories	11
3	Identification and Authentication.....	13
3.1	Naming.....	13
3.1.1	Type of Names.....	13
3.1.2	Needs for names to be meaningful	13
3.1.3	Anonymity of Pseudonymity of Subscribers	13
3.1.4	Rules for interpreting various name forms	13
3.1.5	Uniqueness of Names.....	13
3.1.6	Name claim dispute resolution procedure.....	13
3.1.7	Recognition, Authentication and Role of Trademarks	13
3.2	Initial Identity Validation.....	13
3.2.1	Method to prove possession of Private Keys	13
3.3	Identification and Authentication for Re-key Requests	13
3.3.1	Identification and Authentication for routine re-key	14
3.3.2	Identification and Authentication for Re-key after revocation	14
3.4	Identification and Authentication for Revocation Requests.....	14
4	Certificate Life Cycle Operational Requirements.....	15

4.1	Application.....	15
4.1.1	Submission of Certificate Application	15
4.1.2	Enrolment Process and Responsibilities.....	15
4.2	Certificate Application Processing	15
4.2.1	Performing Identity Proofing Functions	15
4.2.2	Approval or Rejection of Certificate Applications	15
4.2.3	Time to process certificate applications	15
4.3	Certificate Issuance.....	15
4.3.1	CA Actions during Certificate Issuance	15
4.3.2	Notification to Subscriber of Certificate Issuance.....	15
4.4	Certificate Acceptance.....	16
4.4.1	Conduct Constituting Certificate Acceptance	16
4.4.2	Publication of the certificate by the CA	16
4.4.3	Notification of Certificate issuance by the CA to other entities	16
4.5	Key Pair and Certificate Usage	16
4.5.1	CA Private Key and Certificate Usage	16
4.6	Subscriber Private key and Certificate Usage	16
4.6.1	Relying party public key and Certificate Usage.....	16
4.7	Certificate Re-key.....	17
4.7.1	Circumstance for Certificate Re-Key.....	17
4.7.2	Who may request a re-key.....	17
4.7.3	Processing Certificate re-keys	17
4.7.4	Notification of New Certificate Issuance to Subscriber.....	17
4.7.5	Conduct <i>Constituting Acceptance of re-keyed</i> Certificate	17
4.7.6	Publication of the Renewed Certificate by the CA.....	18
4.7.7	Notification of Certificate Issuance by the CA to other entities.....	18
4.8	Certificate Renewal	18
4.9	Certificate Modification.....	18
4.10	Certificate Revocation and Suspension.....	18
4.10.1	Circumstance for revocation of a certificate	18
4.10.2	Who can request revocation of a certificate	18
4.10.3	Procedure for Revocation Request.....	18
4.10.4	Revocation Request Grace Period.....	19
4.10.5	Time within which CA must Process the Revocation Request	19
4.10.6	Revocation Checking Requirements for Relying Parties.....	19
4.10.7	CRL Issuance Frequency.....	19
4.10.8	Maximum Latency of CRLs.....	19
4.10.9	Online Revocation Checking Availability	19
4.10.10	Online Revocation Checking Requirements	19
4.10.11	Other Forms of Revocation Advertisements Available	19
4.10.12	Special Requirements Related To Key Compromise	19
4.10.13	Circumstances for Certificate Suspension	19
4.10.14	Who can Request Suspension	19
4.10.15	Procedure for Suspension Request.....	19
4.10.16	Period for certificate suspension.....	19
4.10.17	Circumstances for Terminating Suspended Certificates	20
4.10.18	Procedure for Terminating the Suspension of a Certificate.....	20
4.10.19	Certificate Status Services.....	20
4.11	End of Subscription	20
4.12	Key Escrow & Recovery	20
4.13	Key Changeover.....	20
5	FACILITY MANAGEMENT & OPERATIONS CONTROLS.....	21

5.1	Physical Controls	21
5.1.1	Site Location & Construction.....	21
5.1.2	Physical Access	21
5.1.3	Power and Air Conditioning.....	21
5.1.4	Water Exposure	21
5.1.5	Fire Prevention and Protection	22
5.1.6	Media Storage.....	22
5.1.7	Waste Disposal	22
5.1.8	Off-Site backup	22
5.2	Procedural Controls	22
5.2.1	Trusted Roles.....	22
5.2.2	Number of Persons Required per Task	23
5.2.3	Identity-proofing for Each Role	23
5.2.4	Separation of Roles	23
5.3	Personnel Controls.....	23
5.3.1	Background, Qualifications, Experience, & Security Clearance.....	23
5.3.2	Background Check Procedures	23
5.3.3	Training Requirements.....	23
5.3.4	Retraining Frequency & Requirements	23
5.3.5	Job Rotation Frequency & Sequence	24
5.3.6	Sanctions for Unauthorised Actions	24
5.3.7	Contracting Personnel Requirements	24
5.3.8	Documentation Supplied To Personnel	24
5.4	Audit Logging Procedures.....	24
5.4.1	Types of Events Recorded.....	24
5.4.2	Frequency of Processing Data.....	24
5.4.3	Retention Period for Security Audit Data.....	24
5.4.4	Protection of Security Audit Data	24
5.4.5	Security Audit Data Backup Procedures	24
5.4.6	Security Audit Collection System (Internal or External).....	24
5.4.7	Notification to Event Causing Subject	24
5.4.8	Vulnerability Assessments	25
5.5	Records Archive	25
5.5.1	Types of Events Archived.....	25
5.5.2	Retention Period for Archive	25
5.5.3	Protection of Archive	25
5.5.4	Archive Backup Procedures.....	25
5.5.5	Requirements for Time-Stamping of Records	25
5.5.6	Archive Collection System (Internal or External).....	25
5.5.7	Procedures to Obtain & Verify Archive Information	25
5.6	Key Changeover	25
5.7	Compromise & Disaster Recovery	26
5.7.1	Incident and Compromise Handling Procedures.....	26
5.7.2	Computing Resources, Software, and/or Data Are Corrupted.....	26
5.7.3	CA Private Key Compromise Recovery Procedures	26
5.7.4	Business Continuity Capabilities after a Disaster	26
5.8	CA & RA Termination.....	26
5.8.1	CA Termination.....	26
6	TECHNICAL SECURITY CONTROLS	27
6.1	Key Pair Generation & Installation	27
6.1.1	Key Pair Generation.....	27
6.1.2	Private Key Delivery to Subscriber.....	27

6.1.3	Public Key Delivery to Certificate Issuer	27
6.1.4	CA Public Key Delivery to Subscribers and Relying Parties	27
6.1.5	Key Sizes	27
6.1.6	Public Key Parameters Generation and Quality Checking	27
6.1.7	Key Usage Purposes	28
6.2	Private Key Protection & Crypto Module Engineering Controls	28
6.2.1	Cryptographic Module Standards & Controls	28
6.2.2	CA Private Key Multi-Person Control	28
6.2.3	Private Key escrow	28
6.2.4	Private Key Backup.....	28
6.2.5	Private Key Archival	28
6.2.6	Private Key Transfer into or from a Cryptographic Module	28
6.2.7	Private Key Storage on Cryptographic Module	28
6.2.8	Method of Activating Private Keys.....	29
6.2.9	Methods of Deactivating Private Keys	29
6.2.10	Methods of Destroying Private Keys	29
6.2.11	Cryptographic Module Rating	29
6.3	Other Aspects of Key Management.....	29
6.3.1	Public Key Archive	29
6.3.2	Certificate Operational Periods and Key Usage Periods.....	29
6.4	Activation Data	29
6.5	Computer Security Controls	29
6.6	Life Cycle Technical Controls	30
6.6.1	System Development Controls.....	30
6.6.2	Security Management Controls.....	30
6.6.3	Life Cycle Security Ratings	30
6.7	Network Security Controls.....	30
6.8	Time Stamping	30
7	CERTIFICATE, CRL, AND OCSP PROFILES	32
7.1	Certificate Profile	32
7.2	CRL Profile	32
7.3	OCSP Profile.....	32
8	COMPLIANCE AUDIT & OTHER ASSESSMENTS.....	33
8.1	Frequency and Circumstances of Assessments.....	33
8.2	Qualifications of Assessor	33
8.3	Topics Covered by Assessment	33
8.4	Actions Taken As A Result Of Deficiency.....	33
8.5	Communication of Results	33
9	OTHER BUSINESS & LEGAL MATTERS	35
9.1	Fees	35
9.2	Financial Responsibility.....	35
9.3	Confidentiality of Business Information	35
1.1.1	Scope of Confidential Information	35
1.1.2	Information not within the Scope of Confidential Information	35
1.1.3	Responsibility to Protect Confidential Information.....	35
9.4	Privacy of Personal Information	35
9.4.1	Privacy Plan.....	35
9.4.2	Information treated as Private	35
9.4.3	Information not deemed Private.....	35
9.4.4	Responsibility to Protect Private Information	35
9.4.5	Notice and Consent to Use Private Information	36
9.4.6	Disclosure Pursuant to Judicial/Administrative Process.....	36

9.4.7	Other Information Disclosure Circumstances.....	36
9.4.8	Intellectual Property Rights	36
9.5	Warranties.....	36
9.5.1	CSCA Warranties.....	36
9.5.2	RA Warranties.....	36
9.5.3	Relying Parties Warranties.....	36
9.5.4	Subscriber Warranties.....	37
9.6	Limitations of Liability	37
9.7	Indemnities.....	37
9.8	Term & Termination	38
9.8.1	Term.....	38
9.8.2	Termination	38
9.8.3	Effect of Termination and Survival.....	38
9.9	Individual Notices & Communications with Participants	38
9.10	Amendments	38
9.10.1	Procedure for Amendment.....	38
9.10.2	Notification Mechanism and Period.....	38
9.10.3	Circumstances under which OID must be changed	38
9.11	Dispute Resolution Provisions.....	38
9.12	Governing Law	39
9.13	Compliance with Applicable Law	39
9.14	Miscellaneous Provisions	39
9.14.1	Entire agreement	39
9.14.2	Assignment	39
9.14.3	Severability	39
9.14.4	Enforcement (Attorney Fees/Waiver of Rights).....	39
9.14.5	Force Majeure.....	39
9.15	Other Provisions.....	39
9.15.1	Fiduciary relationships	39
9.15.2	Administrative processes	39
10	References	40

1 Introduction

1.1 Overview

The Country Signer Certification Authority (CSCA) was established in 2009 by the Federal Public Service Foreign Affairs, Kingdom of Belgium for the purpose of issuing CSCA certificates, Master List Signer Certificates (MLS) and document signer certificates (DSC). As a trust point, the Certification Authority (CA) is required to be governed by a Certificate Policy (hereby referred to as the CP). This document states and establishes the policies of the trust centre to ensure the establishment of a trust relationship between any relying parties and the CA.

The CSCA CP is owned by the Federal Public Service Foreign Affairs and is administered by the Direction General Consular Affairs.

This document specifically describes the CP for the Country Signer Certification Authority for the Kingdom of Belgium.

1.1.1 Certificate Policy

This document outlines the Certificate Policy of the Country Signing Certificate Authority (CSCA). The contents of the CP include the legal and commercial principles for issuance, usage and maintenance of the certificates along with the underlying system. The policy also identifies the legal entities involved in the infrastructure.

CSCA publicly discloses and brings to the attention of the parties concerned the features of certificates issued by it, considerations governing their use, certification processes, rights and obligations of the parties taking part in the certification process and technical and operation activities it carries out in its capacity as CSP under document on the Certificate policy "CP". In addition, the Federal Public Service Foreign Affairs, outlines how the aspects covered by document "CP" are implemented in the document titled "Certification Practice Statement" (to be referred to as CPS hereafter). This document shall be classified accordingly.

The term Machine Readable Document (MRD) is used throughout this CPS. This refers both to Machine Readable Travel Documents, Biometric Residence Permits and any other Machine Readable Documents which may be developed in the future.

1.1.2 CP vs CPS

The Certificate Policy describes what needs to be done and the policies around this. The practice statement describes the manner in which the policy statements need to be executed.

The CPS contains confidential information regarding procedures and policies that need to be executed.

1.1.3 Relationship with other PKI systems

The CSCA sources infrastructure certificates from a management CA.

Certificates may be published to the ICAO PKD which is a global repository of certificates originating from various countries CSCA.

As part of the MRD life cycle, the CSCA also forms part of the issuance system along with the verification.

1.1.4 Scope

This document is limited to the certificate policy executed by the CSCA

1.2 Document Name and Identification

The official name of this document is the “Country Signer Certification Authority – Kingdom of Belgium – Certificate Policy”.

1.3 PKI Participants

The PKI participants are as defined in the table below:

	Certification Authority	Registration Authority	Subscriber	Relying Party
Country Signer Certification Authority	X	X		
Document Signer			X	
MRD				X
Inspection System				X

1.1.5 Certification Authority

The CSCA is the primary trust point for the entire PKI architecture. The specific tasks of the CSCA are:

- The issuance of DSCs
- Publication of CSCA certificates and DS certificates,
- Re-key of the CSCA
- Creation of CSCA link certificates
- Establishment and maintenance of the CP and CPS

1.1.6 Registration Authority (RA)

The CSCA shall act as the RA to manage and approve requests for document signer certificates. The specific roles of the RA include

- Process Certificate application requests in accordance with the CP and applicable RA Agreement, and other policies and procedures with regard to the Certificates issued.
- Maintain and process all supporting documentation related to the Certificate application process,
- Process certificate revocation requests in accordance with this CP and other relevant operational policies and procedures with respect to the certificates issued. Without limitation to the generality of the foregoing, the RA can request the revocation of any certificate that it has approved for issuance according to the conditions described in this document

For this implementation, the RA accepts certificates dispatched manually. It is the job of

the personnel performing the RA role to verify the requests and then process them. An automatic process for certificate request submission may be supported. In this case it is secured by SSL and client certificates.

1.1.7 Subscribers

Subscribers are document signers that sign objects during the personalisation of the MRD. All MRDs are compliant with the ICAO 9303 Standard and the procedure described applies. Document signers use certificates issued by the CSCA for the explicit purpose of MRD issuance.

1.1.8 Relying Parties

A Relying Party is any entity that places trust on information provided by Certificate Service Providers regarding a specific electronic transaction that the relying party uses to accept or reject its participation in the transaction.

The Relying Party is responsible for deciding whether or how to check the validity of the certificate by checking the appropriate certificate status information. The relying party can use the certificate to verify the integrity of a digitally signed message, to identify the creator of a message, or to establish confidential communications with the holder of the certificate. A Relying Party may use information in the certificate (such as certificate policy identifiers) to determine the suitability of the certificate for a particular use.

1.4 Obligations

This sub-component contains, for each entity type, any applicable provisions regarding the entity's obligations to other entities. The obligations are divided into sub sections and these are described in the sections below:

1.1.9 CA Obligations

- Protection of the private signing keys;
- Publication of certificates to the repository; and
- Timely generation of CRLs

1.1.10 RA obligations

- Notification of issuance of a certificate to the subscriber who is the subject of the certificate being issued;
- Notification of issuance of a certificate to others than the subject of the certificate;
- Notification of revocation or suspension of a certificate to the subscriber whose certificate is being revoked or suspended; and
- Notification of revocation or suspension of a certificate to others than the subject whose certificate is being revoked or suspended.

1.1.11 Subscriber obligations:

- Accuracy of representations in certificate application;
- Protection of the entity's private key;
- Restrictions on private key and certificate use; and

- Notification upon private key compromise.

1.1.12 Relying party obligations:

- Verification of purposes for which certificate is used;
- Digital signature verification responsibilities;
- Revocation and suspension checking responsibilities;

1.1.13 Repository obligations

- Timely publication of certificates and revocation information
- Provision of access control requirements if mandated by the CP

1.1.14 Kinds of Certificates issued

The CSCA shall issue the following certificates:

- Self-signed CSCA and CSCA link certificates
- DS Certificates

1.5 Certificate Usage

1.1.15 Acceptable uses

The CSCA certificate shall be the trust point for the country.

The CSCA link certificate shall be used for verification of a CSCA chain

The DSC certificate shall be used only for signing the data groups as stipulated in the ICAO standards [1] for MRDs.

1.1.16 Prohibited uses

Any use not accepted is prohibited.

1.6 Policy Administration

This policy is administered by the following organisations:
Federal Public Service Foreign Affairs, Kingdom of Belgium

1.7 Contact Information

Federal Public Service Foreign Affairs

Karmelietenstraat 15

1000 Brussels

+32 2 501 81 11

All information can be obtained in writing at csc-pass@diplobel.fed.be

2 Publication and repository responsibilities

2.1 Repositories

The CSCA certificate SHALL be made available on the Federal Public Service Foreign Affairs' website: <http://csca-pass.belgium.be>

The CSCA MAY support a repository of DS certificates in LDAP format.

The CSCA MAY publish its certificates and CRL contents to the ICAO PKD

2.1.1 Repository Obligations

Repositories SHALL support the following:

- An appropriate standard based logical access controls wherever applicable
- The availability of the information as required
- Integrity protection where ever applicable to ensure that the data in the repository is fit for purpose

2.2 Publication of Certification Information

The CSCA shall publish information to the designated repository.

2.2.1 Publication of Certificates and Certificate Status

The repository MAY host the following information:

- CSCA certificates in X.509 format
- DS certificates in X.509 format
- Certificate Revocation Lists (CRLs)

2.2.2 Publication of CA Information

Repositories used to publish CA certificates and CRLs, shall employ publishing technology to depending on the publishing target.

2.3 Time and Frequency of publication

The CSCA shall publish certificate following their generation and issue. CRL information shall be published.

The certificates and CRLs shall be published within 48 hours of their creation.

2.4 Access Control on Repositories

Information present in the repository is not subject to any confidentiality requirements however access control requirements are in place as the provision of the certificates is a value added service and any access shall be subject to a cost.

The appropriate authority shall protect repository information not intended for public dissemination or modification. Certificates and certificate status information in the repository shall be made available to the PKI participants and other parties as determined by the applicable agreement as described in this document. For directory search also access restrictions are implemented to prevent misuse and unauthorised harvesting of information and fetch with minimum required information only.

For information present in the ICAO PKD, the ICAO PKD repository standards apply.

3 Identification and Authentication

3.1 Naming

This sections describes the naming associated with the identity of certificates.
The implementation of the naming is as described in the CPS.

3.1.1 Type of Names

Each CA must have a unique and readily identifiable Distinguished Name (DN) according to the X.500 standard. Naming conventions for CAs are approved by CSCA. Details are found in the certificate profiles set forth later in this CP.

3.1.2 Needs for names to be meaningful

The DN for the CSCA shall identify the entity responsible for managing the root authority MRDs.

The DN for the DSC shall identify the entity responsible for creating MRDs.

3.1.3 Anonymity of Pseudonymity of Subscribers

Not applicable.

3.1.4 Rules for interpreting various name forms

The naming convention used by CSCA and DS certificates is ISO/IEC 9595 (X.500) Distinguished Name (DN).

3.1.5 Uniqueness of Names

Names shall be unique.

The CSCA shall assign names to all DSCs.

3.1.6 Name claim dispute resolution procedure

Not applicable.

3.1.7 Recognition, Authentication and Role of Trademarks

Not applicable.

3.2 Initial Identity Validation

3.2.1 Method to prove possession of Private Keys

For CSCA root certificate generation, proof of possession is ensured by the witnesses present during the key ceremony.

For DS certificates, the DS shall generate a signed request and this shall be considered proof of possession of the associated private key

3.3 Identification and Authentication for Re-key Requests

CSCA shall only be re-keyed by authorised personnel.

A DS certificates can be re-keyed

3.3.1 Identification and Authentication for routine re-key

Only an authorised representative is allowed to request re-key of the CSCA or DSC. Re-key only occur in extenuating circumstances and a full investigation is required with documented evidence on the reasons for the re-key request. The CSCA has the right to deny a re-key request.

3.3.2 Identification and Authentication for Re-key after revocation

If a DSC certificate is revoked, an authorised representative of the DSC shall provide sufficient information before CSCA initiates generation of the new DS certificate

3.4 *Identification and Authentication for Revocation Requests*

Revocation requests shall be authenticated to verify that the revocation has been requested by an authorised entity. Acceptable procedures for authenticating the revocation SHALL be implemented.

4 Certificate Life Cycle Operational Requirements

4.1 *Application*

This section specifies the requirements for initial application for certificate issuance.

4.1.1 Submission of Certificate Application

A document signer submits a certificate request manually to the authorised representative of the CSCA. The DS request shall be in PKCS#10 format.

4.1.2 Enrolment Process and Responsibilities

The CSCA shall implement the following enrolment policies:

- The CSCA shall request the identification information
- The origin of the DS request shall be verified
- The proof of possession of the private key shall be verified
- The DS shall agree to the conditions for key usage set forth in this CP

4.2 *Certificate Application Processing*

Applications received for new DSCs shall be processed by the CSCA.

Only the following entities are allowed to submit DSC requests:

Federal Public Service Foreign Affairs

4.2.1 Performing Identity Proofing Functions

For first DS requests, identity proofing functions SHALL be performed manually.

Requests are submitted manually via a mass storage device with the custodian entrusted with the task of securing the request during transport. The identity of the custodian shall be verified in order to ensure that the request is genuine.

4.2.2 Approval or Rejection of Certificate Applications

The Federal Public Service Foreign Affairs is required to approve requests for new DS certificates.

4.2.3 Time to process certificate applications

The application for a new DSC MAY NOT exceed 2 weeks.

4.3 *Certificate Issuance*

Key generation and certificate issuance requires the action of of the CSCA and SHALL take place in the secure area of the trust centre.

4.3.1 CA Actions during Certificate Issuance

The CA would need to perform specific actions as part of the certificate issuance process. The CA actions are defined in the CPS. If an application is approved by the Federal Public Service Foreign Affairs, then the CSCA is under obligation to fulfil this.

4.3.2 Notification to Subscriber of Certificate Issuance

The CSCA SHALL notify all subscribers of the following:

- Issue of a new document signer certificate
- Issuance of a new CRL
- Update to the CP and CPS

4.4 *Certificate Acceptance*

This section describes the certificate acceptance.

4.4.1 Conduct Constituting Certificate Acceptance

A certificate request approved by the Federal Public Service Foreign Affairs is assumed to be accepted since this entity has the final responsibility of the infrastructure. The administrator however is responsible for verifying that the certificate is fit for purpose.

4.4.2 Publication of the certificate by the CA

The CSCA MAY publish new certificates to the repository. The list of repositories is under section 2.1

4.4.3 Notification of Certificate issuance by the CA to other entities

The necessary entities should be informed when in the event of a cross certification process.

4.5 *Key Pair and Certificate Usage*

4.5.1 CA Private Key and Certificate Usage

The CSCA private key shall be used for the explicit purpose of certificate and CRL signing.

4.6 *Subscriber Private key and Certificate Usage*

DSs and MLSs shall use their certificates exclusively for legal and authorised purposes in accordance with the terms and conditions of the agreement, this CP, CPS and applicable laws. CAs shall protect their private keys from access by any other party and shall notify the CSCA upon the compromise of the private key or any reasonable suspicion of compromise.

4.6.1 Relying party public key and Certificate Usage

Relying parties shall use public key document signing certificates and associated public keys for the verification of the signed object data (SOD) on a MRD.

Relying parties shall use public key master list signing certificates and associated public keys for the verification of the master list signature.

The relying party is solely responsible for deciding whether or not to rely on the information in a certificate provided to accept or reject their participation in the transaction.

4.7 Certificate Re-key

Re-keying (key update) a certificate consists of creating new certificates with a different Key pair while retaining other Subject information from old certificate. The new certificate may be assigned a different validity period and/or signed using a different issuing CA private key.

4.7.1 Circumstance for Certificate Re-Key

The Federal Public Service Foreign Affairs may take a decision to re-key the CSCA if members of the council have reason to do so.

The DSC shall be re-keyed when:

- The certificate is about to expire
- The DS private key is compromised
- Executive decision by the Federal Public Service Foreign Affairs

The MLS shall be re-keyed when:

- The certificate is about to expire
- The MLS private key is compromised
- Executive decision by the Federal Public Service Foreign Affairs

4.7.2 Who may request a re-key

For the CSCA only the Federal Public Service Foreign Affairs may request a re-key.

For DSCs, the owner of the document signing entity MAY request a re-key. In the event this occurs, the Federal Public Service Foreign Affairs is required to approve the re-key.

For MLS, the owner of the MLS entity MAY request a re-key. In the event this occurs, the Federal Public Service Foreign Affairs is required to approve the re-key.

The CSCA MAY allow automatic DS re-key on certificate expiry only.

4.7.3 Processing Certificate re-keys

For CSCA root certificates, the CSCA root needs to be re-keyed. A key ceremony is required for this purpose. For re-key, generation of CSCA link certificates is also required.

Manual DS re-key events require approval by the Federal Public Service Foreign Affairs.

Manual MLS re-key events require approval by the Federal Public Service Foreign Affairs.

DS Certificate renewals MAY be automatic if no revocation has taken place.

4.7.4 Notification of New Certificate Issuance to Subscriber

If CSCA certificates are re-keyed, DSC and MLS certificates shall continue to be valid. The Authorised representative of the DS shall be informed in writing of the issue of a new CSCA.

4.7.5 Conduct *Constituting Acceptance of re-keyed Certificate*

If the DS does not respond within 24 hours of certificate deliverance, the certificate is

deemed to be accepted.

4.7.6 Publication of the Renewed Certificate by the CA

The certificate shall be published soon after issuance in accordance with the policy requirements set out by the repository section.

4.7.7 Notification of Certificate Issuance by the CA to other entities

The following entities MUST be informed of the issuance of re-key of new certificates.

- All applicable document signer entities;
- Federal Public Service Foreign Affairs;
- Foreign countries with whom bilateral agreements exist

Notification methods are described in the CPS.

4.8 *Certificate Renewal*

Certificate renewal is not permitted.

4.9 *Certificate Modification*

For certificate modification, procedures for re-key are followed.

4.10 *Certificate Revocation and Suspension*

A Certificate shall be revoked when the binding between the document signer and the document signer public key defined within a certificate is no longer considered valid.

4.10.1 Circumstance for revocation of a certificate

The CSCA certificate is not subject to revocation.

DS certificates issued by the CSCA can be revoked for the following reasons:

- Termination of business
- Key compromise
- Trust centre compromise
- Other reasons as decided by the Federal Public Service Foreign Affairs

4.10.2 Who can request revocation of a certificate

Revocation of DS certificate can be requested by representatives of any of the following entities:

Federal Public Service Foreign Affairs

4.10.3 Procedure for Revocation Request

The authorised representative shall be contacted via the appropriate government channels via e-mail, telephone or personal appointment to communicate the desire to revoke DS. Contact details for the CSCA are provided in this document.

The person requesting a revocation request must at the minimum specify the following:

- The DN of the DS
- The location of the DS

- The revocation reason

4.10.4 Revocation Request Grace Period

There is no revocation grace period once a revocation request has been verified.

4.10.5 Time within which CA must Process the Revocation Request

Authorised certificate revocation SHALL be processed within 48 *hours*.

4.10.6 Revocation Checking Requirements for Relying Parties

Relying parties SHALL comply with the signature validation requirements defined in this CP and the associated CPS.

4.10.7 CRL Issuance Frequency

The CSCA will publish its CRL no less frequently than once every ninety days and at the time of any certificate revocation of certificate issued by it.

4.10.8 Maximum Latency of CRLs

CRLs shall be published immediately in the repositories after certificate revocation. Certificate status information must be updated immediately.

4.10.9 Online Revocation Checking Availability

No online revocation checking is supported.

4.10.10 Online Revocation Checking Requirements

Not applicable.

4.10.11 Other Forms of Revocation Advertisements Available

Not applicable.

4.10.12 Special Requirements Related To Key Compromise

Relying parties will be responsible for any losses resulting from the use of a compromised key if they continue to use it with the knowledge that it is compromised.

4.10.13 Circumstances for Certificate Suspension

Not supported.

4.10.14 Who can Request Suspension

Not applicable.

4.10.15 Procedure for Suspension Request

Not applicable.

4.10.16 Period for certificate suspension

Not applicable.

4.10.17 Circumstances for Terminating Suspended Certificates

Not applicable.

4.10.18 Procedure for Terminating the Suspension of a Certificate

Not applicable

4.10.19 Certificate Status Services

The Status of public certificates is available from CRL's in the repositories.

4.11 End of Subscription

Not applicable.

4.12 Key Escrow & Recovery

Not applicable.

4.13 Key Changeover

Not applicable.

5 FACILITY MANAGEMENT & OPERATIONS CONTROLS

5.1 *Physical Controls*

This section describes the physical controls in place at the trust centre.

5.1.1 Site Location & Construction

The following physical controls apply to the site location and construction

- The site construction **MUST** be robust
- All main entrances have continuous video monitoring and access controlled doors
- The site **MUST** protect ICT equipment from natural elements.
- The site **MUST** ensure a temperature conducive to the operation of electronic equipment

5.1.2 Physical Access

The CA equipment shall always be protected from unauthorised access. The following physical access control requirements shall apply

- Entry to the premises shall be logged and secured
- Visitors are always accompanied by IT personnel of the Federal Public Service Foreign Affairs.
- Access to the secure areas shall be secured using access controlled doors.

5.1.3 Power and Air Conditioning

The CAs shall have backup capability sufficient to automatically lockout input, finish any pending actions, and record the state of the equipment before lack of power or air conditioning causes a shutdown. Any of the CA on-line servers (e.g., CAs hosting directories) shall be provided with uninterrupted power sufficient for a minimum of six hours operation in the absence of commercial power, to support a smooth shut down of the CA operations.

The CA shall have sufficient cooling and ventilation available to prevent any disruption of services caused by overheating of hardware or poor air circulation. The air conditioning and ventilation is required to be supported by the uninterrupted power supply.

5.1.4 Water Exposure

Exposure to water can cause significant damage to information processing hardware and consequently affect the service offered by the trust centre. As a control The following shall be mandated to prevent damage caused by water exposure.

- The building shall be waterproofed to ensure that no leakage occurs causing exposure to water
- Flood protection shall be in place at various locations in the building to ensure that appropriate personnel are alerted in the event that flooding does occur

5.1.5 Fire Prevention and Protection

Exposure to fire can cause significant and instant damage to information processing hardware and consequently affect the service offered by the trust centre. As a consequence, the following shall be mandated to prevent damage caused by fire exposure.

- Fire alerting shall be in place at various locations throughout the building
- Staff SHALL have training on procedures in the event of a fire
- Fire extinguishing mechanisms shall be in place

5.1.6 Media Storage

Media applicable to information processing can take the following forms.

- Tangible information: Paper
- Intangible information: DVD, USB Sticks, External hard drives

The following controls apply to media

- Confidential media should be stored in a designated archive room
- Intangible media MUST be scrutinised by an operator with role system administrator or higher before leaving the room
- Tangible media with security classification CONFIDENTIAL or higher MUST be stored in a safe when not in the archive room

5.1.7 Waste Disposal

The following controls shall apply to waste disposal:

- Waste SHALL be disposed in a manner which poses no hazard to the environment
- Confidential waste (documents, media) SHALL be disposed off in a manner in which information leakage is prevented

5.1.8 Off-Site backup

Backup MUST be taken to an off site location in order to facilities disaster recovery and business continuity.

5.2 *Procedural Controls*

5.2.1 Trusted Roles

A trusted role is one whose incumbent performs functions that can introduce security problems if not carried out properly, whether accidentally or maliciously. The people selected to fill these roles must be extraordinarily responsible or the integrity of the PKI is weakened. The functions performed in these roles form the basis of trust for all uses of the Centre. The following are the trusted roles for a CA:

- CA Administrator
- Auditor

5.2.2 Number of Persons Required per Task

The policy authority shall ensure separation of duties for critical CA functions to prevent one person from maliciously using the PKI systems without detection. Each user's system access is limited to those actions for which they are required to perform in fulfilling their responsibilities. Separate individuals shall fill each of the roles specified. This provides the maximum security and affords the opportunity for the greatest degree of checks and balances over the system operation.

Dual Control is to be enforced for at least the following:

- Generating of DSC certificate
- Generating of MLS certificate
- Activation of the CSCA certificate signing private key
- CSCA Re-key operations
- Backup of CSCA contents

5.2.3 Identity-proofing for Each Role

- An individual shall identify and authenticate himself before being permitted to perform any actions set forth above for that role or identity.
- Personal assigned roles MUST be employed by the Federal Public Service Foreign Affairs,
- Cards, tokens PINs and other instruments issued for specific roles are not transferable.

5.2.4 Separation of Roles

The CSCA MAY ensure that no individual shall be assigned more than one trusted role. Separation of duty SHALL be enforced for tasks described in section 5.2.2.

5.3 *Personnel Controls*

5.3.1 Background, Qualifications, Experience, & Security Clearance

All persons filling trusted roles are selected on the basis of skills, loyalty, trustworthiness, and integrity. Persons should at the minimum have no criminal record. The requirements governing the qualifications, selection and oversight of individuals who operate, manage, oversee, and audit the CA are set forth in the CPS.

5.3.2 Background Check Procedures

Background check procedures are described in the CPS and demonstrate that requirements set forth in Section 2.3.1 are met.

5.3.3 Training Requirements

The CSCA SHALL ensure that all personnel receive appropriate training. Such training shall address relevant topics such as security requirements, operational responsibilities and associated procedures.

5.3.4 Retraining Frequency & Requirements

Individuals responsible for PKI roles are made aware of changes in the CA operation. Any significant change to the operations shall have a training (awareness) plan, and the execution of such plan shall be documented. The CSCA shall review and update its

training program regularly to accommodate changes in the CA system.

5.3.5 Job Rotation Frequency & Sequence

Not applicable

5.3.6 Sanctions for Unauthorised Actions

Sanctions for unauthorised actions shall be implemented on a case by case basis.

5.3.7 Contracting Personnel Requirements

Contractor personnel employed to perform functions pertaining to the CA shall be under adequate supervision and perform only assigned tasks.

5.3.8 Documentation Supplied To Personnel

CSCA SHALL make available to its personnel its CP, CPS, and any relevant documents required to perform their jobs.

5.4 *Audit Logging Procedures*

Audit log files are generated for all events relating to the security of the CSCA and its RA. The security audit logs for each auditable event defined in this section are maintained for 10 years.

5.4.1 Types of Events Recorded

The CSCA shall ensure recording of all events in audit log files relating to the security of the CA system hosted in the datacentre, including but not limited to, routers, firewalls, directories and servers hosting CA, RA and other software. All security audit capabilities of the CA operating system and CA applications shall be enabled.

5.4.2 Frequency of Processing Data

Audit logs are required to be processed at least once a year.

5.4.3 Retention Period for Security Audit Data

The CSCA shall retain all system generated (electronic) and manual audit records on-site for a period not less than twelve months from the date of creation.

5.4.4 Protection of Security Audit Data

The CSCA shall protect the electronic audit log system and audit information captured electronically or manually from unauthorised viewing, modification, deletion or destruction.

5.4.5 Security Audit Data Backup Procedures

The CSCA shall back up all audit logs and audit summaries.

5.4.6 Security Audit Collection System (Internal or External)

The CSCA SHALL implement log collection with integrity protection. External logging MAY be implemented.

5.4.7 Notification to Event Causing Subject

The event causing subjects are not notified.

5.4.8 Vulnerability Assessments

Routine vulnerability self-assessments of security controls MAY be performed by the CSCA.

5.5 *Records Archive*

5.5.1 Types of Events Archived

The CSCA archive records shall be sufficiently detailed to establish the proper operation of the CA, or the validity of any certificate (including those revoked or expired) issued by the CA.

5.5.2 Retention Period for Archive

The retention period is 10 years.

5.5.3 Protection of Archive

The following controls SHALL be implemented for protection:

- Only authorised individuals shall be permitted to review the archive.
- The contents of the archive shall not be released except as determined by the Federal Public Service Foreign Affairs, Kingdom of Belgium or as required by law.
- Records and material information relevant to use of, and reliance on, a certificate shall be archived.
- Archive media shall be stored in a secure storage facility separate from the component itself.
- Any secondary site must provide equivalent protection and access controls as the primary site.

5.5.4 Archive Backup Procedures

An archive backup policy has been implemented.

5.5.5 Requirements for Time-Stamping of Records

Certificates, CRLs, and other revocation database entries SHALL contain time and date information. Also all the system logs MAY be time stamped.

5.5.6 Archive Collection System (Internal or External)

An archive collection system MAY be implemented.

5.5.7 Procedures to Obtain & Verify Archive Information

Archive, where present SHALL have procedures to obtain and verify them.

5.6 *Key Changeover*

The CA system utilised by the CSCA supports key rollover, allowing CA keys to be changed periodically as required to minimize risk to the integrity of the CSCA. Once changed the new key is used for certificate signing purposes. The unexpired older keys are used to sign CRL's until all certificates signed by the unexpired older private key have expired.

5.7 *Compromise & Disaster Recovery*

This subcomponent describes requirements relating to notification and recovery procedures in the event of compromise or disaster. Each of the following circumstances may need to be addressed separately:

- The recovery procedures used if computing resources, software, and/or data are corrupted or suspected to be corrupted. These procedures describe how a secure environment is re-established, which certificates are revoked, whether the entity key is revoked, how the new entity public key is provided to the users, and how the subjects are recertified.
- The recovery procedures used if the entity public key is revoked. These procedures describe how a secure environment is re-established, how the new entity public key is provided to the users, and how the subjects are recertified.
- The recovery procedures used if the entity key is compromised. These procedures describe how a secure environment is re-established, how the new entity public key is provided to the users, and how the subjects are recertified.
- The CA's procedures for securing its facility during the period of time following a natural or other disaster and before a secure environment is re-established either at the original site or a remote hot-site. For example, procedures to protect against theft of sensitive materials from an earthquake-damaged site.

5.7.1 Incident and Compromise Handling Procedures

If the CSCA detects a potential hacking attempt or other form of compromise to a CA, it shall perform an investigation in order to determine the nature and the degree of damage.

5.7.2 Computing Resources, Software, and/or Data Are Corrupted

CSCA SHALL maintain backup copies of hardware, system, databases, and private keys in order to rebuild the CA capability in case of software and/or data corruption.

5.7.3 CA Private Key Compromise Recovery Procedures

CA private key compromise recovery procedures SHALL be specified.

5.7.4 Business Continuity Capabilities after a Disaster

In the case of a disaster whereby CSCA installation is physically damaged and all copies of the CA Signing Key are destroyed as a result, the CSCA shall continue to remain valid. A new CSCA shall be created using new infrastructure with re-use wherever possible.

5.8 *CA & RA Termination*

5.8.1 CA Termination

If any CA terminates operation for convenience, contract expiration, re-organisation, or other non-security related reason, the Agreement between the CSCA and the DS entity shall set forth what actions are to be taken to ensure continued support for certificates previously issued by the CA. At a minimum, such actions shall include preservation of the CA information archive described in the CSCA CP and CPS.

6 TECHNICAL SECURITY CONTROLS

6.1 Key Pair Generation & Installation

6.1.1 Key Pair Generation

CSCA Key generation procedures SHALL be documented. CSCA key pair generation shall be witnessed and attested by a party separate from the CA trusted roles as part of a key ceremony. Key pair generation must be performed using trustworthy systems and processes that provide the required cryptographic strength of the generated keys, and prevent the loss, disclosure, modification, or unauthorised use of such keys. CSCA SHALL use Hardware Security Modules (HSMs) for CA key generation and storage. The Hardware Security Modules (HSM's) used for key generation meet the requirements of FIPS 140-2 Level 3 to store the CA keys.

6.1.2 Private Key Delivery to Subscriber

Subscriber private keys shall not be generated on the CA.

6.1.3 Public Key Delivery to Certificate Issuer

DS public keys shall be delivered to to the CSCA for certification using a manual process. An automated process MAY be established between the DS and the CSCA for automatic public key delivery.

6.1.4 CA Public Key Delivery to Subscribers and Relying Parties

The CSCA shall ensure that their subscribers and relying parties receive and maintain the trust anchor in a trustworthy fashion. Methods for trust anchor delivery MAY include:

- A trusted role loading the trust anchor onto tokens delivered to subscribers via secure mechanisms,
- Distribution of trust anchor through secure out-of-band mechanisms,
- Calculation and comparison of trust anchor hash or fingerprint against the hash made available via authenticated out-of-band mechanisms
- Downloading trust anchor from web sites secured with a currently valid certificate of equal or greater assurance level than the certificate being downloaded and the site trust anchor already on the subscriber system via secure means.

6.1.5 Key Sizes

CSCA	256
DS	256

6.1.6 Public Key Parameters Generation and Quality Checking

The following parameters and algorithms SHALL be supported:

- CSCA: ECDSA, prime256v1 named curve, SHA-256
- DS: ECDSA, prime256v1 named curve, SHA-256

6.1.7 Key Usage Purposes

CSCA private keys are used for certificate signing and CRL signing.
DSC private keys SHALL be used for document signing.
MLS private keys SHALL be used for master list signing.

6.2 Private Key Protection & Crypto Module Engineering Controls

6.2.1 Cryptographic Module Standards & Controls

Cryptographic modules employed shall comply with FIPS-PUB 140-2 "Security Requirements for Cryptographic Modules".

6.2.2 CA Private Key Multi-Person Control

Using of CSCA Private signing key shall require action by multiple persons as described in same section of CSCA CPS.

6.2.3 Private Key escrow

Not applicable.

6.2.4 Private Key Backup

The CSCA signing private key shall be backed up under the same multi-person control as the original signing Key. Backup shall be taken at the time of the key ceremony.

6.2.5 Private Key Archival

A complete history of all encryption private keys and certificates issued SHALL be maintained for CSCA supporting functions.

6.2.6 Private Key Transfer into or from a Cryptographic Module

For the CSCA private keys:

- The CSCA private keys shall be generated in and remain in the same hardware cryptographic module.
- The CSCA private key SHALL never be temporarily or permanently saved in software for any purpose.

For the DS private keys:

- The DS private keys shall be generated in and remain in the same hardware cryptographic module.
- The DS private key SHALL never be temporarily or permanently saved in software for any purpose.

6.2.7 Private Key Storage on Cryptographic Module

The CSCA Private Keys MUST be stored on FIPS 140-2 Level 3 cryptographic module, in encrypted form.

The DS Private Keys MUST be stored on FIPS 140-2 Level 3 cryptographic module, in encrypted form.

The MLS Private Keys MUST be stored on FIPS 140-2 Level 3 cryptographic module, in encrypted form.

6.2.8 Method of Activating Private Keys

The CSCA private key SHALL be activated by the main stakeholders and authorised personnel by supplying their activation data. Such activation data SHALL be held on secure media and shall require the successful completion of an authentication process using a password or PIN.

6.2.9 Methods of Deactivating Private Keys

A CSCA private keys MAY be deactivated by the main stakeholders and authorised personnel by removing their secure media and storing it in a secure container or environment when not in use.

6.2.10 Methods of Destroying Private Keys

All private signing and keys MAY be destroyed when they are no longer needed, or when the Certificates to which they correspond expire or are revoked.

6.2.11 Cryptographic Module Rating

The cryptographic module for storage and generation of keys MUST be FIPS 104-2 compliant.

6.3 Other Aspects of Key Management

6.3.1 Public Key Archive

The Public Key is archived as part of the certificate archive process.

6.3.2 Certificate Operational Periods and Key Usage Periods

The table below shows key usage periods and maximum certificate lifetime:

Key/Certificate	Key Length in Bits	Maximum Validity Period
CSCA signing key and certificate	256	12 years, 4 months and 7 days
DS signing key and certificate	256	7 years, 3 months, 27 days
MLS signing key and certificate	256	3 months, 15 days

6.4 Activation Data

Activation data shall be required by both CSCA and DS private keys.

6.5 Computer Security Controls

CSCA and DS components MAY include the following computer security controls:

- Require authenticated logins for trusted roles;
- Provide Discretionary Access Control;
- Provide a security audit capability (protected in integrity);
- Prohibit object re-use;

- Require use of cryptography for session communication and database security;
- Require a trusted path for identification and authentication;
- Provide domain isolation for process;
- Provide self-protection for the operating system.

6.6 *Life Cycle Technical Controls*

6.6.1 System Development Controls

The configuration of the CSCA and DS systems as well as any modifications and upgrades shall be documented and controlled. There shall be a mechanism for detecting unauthorised modification to software or configuration. A formal configuration management methodology shall be used for installation and ongoing maintenance of the system.

6.6.2 Security Management Controls

The entire infrastructure inclusive of the CSCA and DS shall operate under an existing security management system.

6.6.3 Life Cycle Security Ratings

Not applicable.

6.7 *Network Security Controls*

Not applicable as the CSCA is an offline system.

6.8 *Time Stamping*

Not applicable

7 CERTIFICATE, CRL, AND OCSP PROFILES

7.1 *Certificate Profile*

The certificate profile for the CSCA, MLS and DSC certificates is defined in section 3.2.1 Certificate Profiles of the Final Technical Report LDS and PKI Maintenance [3] and the Naming and Profile document for the Country Signing Certification Authority.

7.2 *CRL Profile*

The CRL profile is defined in section 3.2.1 Certificate Profiles of the Final Technical Report LDS and PKI Maintenance [3] and the Naming and Profile document for the Country Signing Certification Authority.

7.3 *OCSP Profile*

Not applicable.

8 COMPLIANCE AUDIT & OTHER ASSESSMENTS

This section describes compliance and other auditing requirements.

8.1 Frequency and Circumstances of Assessments

The CSCA and DS systems shall be subjected to periodic compliance audits which are no less frequent than once every 2 years and after each significant change to the deployed procedures and techniques. Moreover, the Federal Public Service Foreign Affairs, may require ad-hoc compliance audits of CSCA to validate that it is operating in accordance with the respective CP, CPS, and other supporting operational policies and procedures.

8.2 Qualifications of Assessor

The auditor shall have prior experience in the audit of certification authorities.

8.3 Topics Covered by Assessment

The audit will verify if the CSCA is in compliance with requirements specified in the CP and the CPS.

8.4 Actions Taken As A Result Of Deficiency

Actions shall be taken as a result of the discovery of any deficiency. The actions taken shall be classified into the following:

- Corrective
- Detective

8.5 Communication of Results

An Audit Compliance Report, including identification of corrective measures taken or being taken by the audited party, shall be provided to the Federal Public Service Foreign Affairs, .

9 OTHER BUSINESS & LEGAL MATTERS

9.1 Fees

No fees are applicable to this infrastructure.

9.2 Financial Responsibility

No entities involved in this system are required to meet any financial responsibility.

9.3 Confidentiality of Business Information

Information pertaining to the CA and not requiring protection may be made publicly available at the discretion of the authority. Specific confidentiality requirements for business information are defined in the Privacy Act (11/12/1998)

1.1.1 Scope of Confidential Information

Information will be classified prior to use. Any unclassified information SHALL not be used.. Information classified as confidential or as such shall be handled in accordance with the information classification policy (Privacy Act 11/12/1998)

1.1.2 Information not within the Scope of Confidential Information

This is determined by the information classification policy.

1.1.3 Responsibility to Protect Confidential Information

All participants shall be responsible for protecting the confidential information they possess in accordance with the information classification policy and applicable laws and agreements.

9.4 Privacy of Personal Information

9.4.1 Privacy Plan

All Subscribers identifying information as defined by Privacy policy shall be protected from unauthorised disclosure.

9.4.2 Information treated as Private

Personal information received by the DS for signing is treated as private. These include the personal data for generating the signed object data (SOD) in accordance with the ICAO standard [1].

9.4.3 Information not deemed Private

Any information not deemed private shall be handled according to the information classification policy determined prior to its release.

9.4.4 Responsibility to Protect Private Information

Any sensitive information shall be explicitly identified in the agreement with the contracting party. Access to this information shall be restricted to those with an official need-to-know in

order to perform their official duties.

9.4.5 Notice and Consent to Use Private Information

Requirements for notice and consent to use private information are defined in the respective agreements and privacy policy.

9.4.6 Disclosure Pursuant to Judicial/Administrative Process

Any disclosure shall be handled in accordance with the privacy policy.

9.4.7 Other Information Disclosure Circumstances

Any disclosure shall be handled in accordance with the privacy policy.

9.4.8 Intellectual Property Rights

The Federal Public Service Foreign Affairs own all intellectual property rights with respect to the CSCA, DS and other supporting software.

9.5 *Warranties*

9.5.1 CSCA Warranties

The CSCA, will warrant and agree to:

- Provide the operational infrastructure and certification services;
- Provide certification and repository services consistent with this CP, CPS and Operating Policies and Procedures;
- Use its private signing key only to sign certificates and CRLs and for no other purpose;
- Perform authentication and identification procedures in accordance with applicable Agreement and Operational Policies and Procedures;
- Provide certificate and key management services including certificate issuance, publication, revocation and key renewal and update in accordance with the CSCA CP and CPS.
- Ensure that CA personnel use private keys issued for the purpose of conducting CA duties only for such purposes;

9.5.2 RA Warranties

An RA who performs registration functions warrants that it shall comply with the stipulations of this CP, and the associated CPS. An RA who is found to have acted in a manner inconsistent with these obligations is subject to revocation of RA responsibilities.

9.5.3 Relying Parties Warranties

Relying Parties who rely upon the certificates issued under this PKI shall:

- Use the certificate for the purpose for which it was issued, as indicated in the certificate information (e.g., the key usage extension);
- Verify the Validity by ensuring that the Certificate has not Expired
- Establish trust in the CA who issued a certificate by verifying the certificate path in accordance with the guidelines set by the X.509 Version 3 Amendment;
- Ensure that the Certificate has not been suspended or revoked by accessing current revocation status information available at the location specified in the Certificate to be relied upon

- Determine that such Certificate provides adequate assurances for its intended use.

9.5.4 Subscriber Warranties

(i) Subscriber is obligated to:

- Secure private key and take reasonable and necessary precautions to prevent loss, disclosure, modification, or unauthorized use of the private key. This includes password, hardware token, or other activation data that is used to control access to the Subscriber's private key;
- Use Subscriber Certificate only for its intended uses as specified by the CSPs
- Notify the CSP in the event of a key compromise immediately whenever the Subscriber has reason to believe that the Subscriber's private key has been lost, accessed by another individual, or compromised in any other manner;
- Use the Subscriber Certificate that does not violate applicable laws; and
- Immediately cease use of the Subscriber Certificate upon termination of Subscriber Agreement, revocation or expiration of the Subscriber Certificate.

(ii) Subscriber agrees that any use of the Subscriber Certificate to sign or otherwise approve the contents of any electronic record or message is attributable to Subscriber. Subscriber agrees to be legally bound by the contents of any such electronic record or message.

9.6 *Limitations of Liability*

Limitations on Liability

- The CSCA will not incur any liability to Subscribers or any person to the extent that such liability results from their negligence, fraud or wilful misconduct.
- The CSCA assumes no liability whatsoever in relation to the use of Certificates or associated Public-Key/Private-Key pairs issued under this policy for any use other than in accordance with this policy. Subscribers will immediately indemnify the CSCA from and against any such liability and costs and claims arising there from.
- The CSCA will not be liable to any party whosoever for any damages suffered whether directly or indirectly as a result of an uncontrollable disruption of its services.
- Subscribers to compensate a relying party which incurs a loss as a result of the Subscriber's breach of Subscriber agreement.
- Relying parties shall bear the consequences of their failure to perform the relying party obligations.
- Registration authorities shall bear the consequences of their failure to perform the registration authorities obligations described in the registration authorities agreement.
- The CSCA denies any financial or any other kind of responsibility for damages or impairments resulting from its CA operation.

9.7 *Indemnities*

The Federal Public Service Foreign Affairs shall indemnify, defend and hold harmless:

- The CSCA, its directors, officers, employees, agents, consultants, and subsidiaries from any and all claims, damages, costs (including, without limitation, attorney's fees), judgments, awards or liability,
- The CSCAs own employees, arising from any of the CSCA operations and activities as a CSCA of any entity or services subordinated or outsourced by the CSCA,
- Any parties relying on the CSCA Certificates, or arising as a result of an infringement or violation of any patents, copyrights, trade secrets, licenses, or other

property rights of any third party.

9.8 *Term & Termination*

9.8.1 Term

The CP becomes effective upon publication in the repository. Amendments to this CP become effective upon publication in the repository.

9.8.2 Termination

This CP as amended from time to time shall remain in force until it is replaced by a new version published on the ministry website.

9.8.3 Effect of Termination and Survival

Upon termination of this CP, participants are nevertheless bound by its terms for all certificates issued for the remainder of the validity periods of such certificates.

9.9 *Individual Notices & Communications with Participants*

Communication shall be through a broadcast mechanism through the Federal Public Service Foreign Affairs' website.

Appropriate government channels for communication shall be employed for communication between the various participants.

9.10 *Amendments*

9.10.1 Procedure for Amendment

The Federal Public Service Foreign Affairs, Kingdom of Belgium shall review this CP regularly in case of system changes. Errors, updates, or suggested changes to this CP shall be communicated to the PKI participants and Subscribers. Such communication shall include a description of the change, a change justification, and contact information for the person requesting the change as per the Change Management Policy.

9.10.2 Notification Mechanism and Period

This CP and any subsequent changes shall be made available to the PKI Participants within one week of approval. The Federal Public Service Foreign Affairs reserves the right to amend this CP without notification for amendments that are not material, including without limitation corrections of typographical errors, changes to URL's, and changes to contact information. All the PKI Participants and other parties designated by the Federal Public Service Foreign Affairs shall provide their comments to the Federal Public Service Foreign Affairs.

9.10.3 Circumstances under which OID must be changed

The policy OID shall only change if the change in the CP results in a material change to the trust by the relying parties, as determined by the Federal Public Service Foreign Affairs in its sole discretion.

9.11 *Dispute Resolution Provisions*

The use of certificates issued by this CA is governed by contracts, agreements, and standards set forth by the CA. Those contracts, agreements and standards include dispute

resolution policy and procedures that shall be employed in any dispute arising from the issuance or use of a certificate governed by this CP. The Dispute Resolution mechanism is described in the Dispute Resolution Policy.

9.12 Governing Law

This document is governed by Belgian Law.

9.13 Compliance with Applicable Law

This CP is subject to Belgian law.

9.14 Miscellaneous Provisions

9.14.1 Entire agreement

No Stipulation

9.14.2 Assignment

Except where specified by other contracts, no party may assign or delegate this CP or any of its rights or duties under this CP, without the prior written consent of the authority.

9.14.3 Severability

Should it be determined that one section of this CP is incorrect or invalid, the other sections of this CP shall remain in effect until the CP is updated.

9.14.4 Enforcement (Attorney Fees/Waiver of Rights)

No Stipulation.

9.14.5 Force Majeure

The CSCA shall not be liable for any failure or delay in its performance under this CP due to causes that are beyond its reasonable control, including, but not limited to, an act of God, act of civil or military authority, fire, epidemic, flood, earthquake, riot, war, failure of equipment, failure of telecommunications lines, lack of Internet access, sabotage, and reasons beyond provisions of the governing law.

9.15 Other Provisions

9.15.1 Fiduciary relationships

The CSCA shall not have relations with any other CA.

9.15.2 Administrative processes

No Stipulation.

10 References

- [1] ICAO Document 9303 – Machine Readable Travel Documents
<http://www.icao.int/publications/pages/publication.aspx?docnum=9303>
- [2] ICAO Public Key Directory (PKD)
<http://www.icao.int/Security/mrtd/Pages/icaoPKD.aspx>
- [3] Final Technical Report LDS and PKI Maintenance
http://www.icao.int/Meetings/TAG-MRTD/TagMrtd22/TAG-MRTD-22_WP07.pdf
- [4] Naming and Profile Document, Country Signing Certification Authority, Kingdom of Belgium